React 原型角色权限分视图实施方案

> 版本: v3.0
>
> 日期: 2026-04-13
>
> 依据: PRD v1.8 / RBAC*MATRIX v2.0 / PAGE*ROLE*VISIBILITY*MATRIX v1.0
>
> 范围: React 原型（ `frontend/` ），mock 角色切换，不含真实后端鉴权
>
> 变更:
>
> - v3.0 — 采用整区域隐藏策略替代字段级 `***` 脱敏；补全 30+ 页面的角色适配；新增 `canViewFinancialData` / `canViewPII` helper；ROUTE_RULES 从 13 条扩展至 28 条
> - v2.0 — 角色从 5 个扩展至 7 个内部角色（新增 `maintenance_staff` 、 `property_inspector` 、 `report_viewer` ）

一、目标

在 React 原型中实现**页面级 / 功能级**两层权限控制（整区域隐藏），覆盖 7 个内部角色、30+ 页面，通过 Profile 页角色切换器演示不同角色体验。排除二房东（ `sub_landlord` ）。

> **v3.0 策略变更**: 放弃 `<MaskedField>` 字段级脱敏（ `***` ），改为整区域隐藏——无权限时隐藏整个卡片/区域/列，不渲染 DOM 节点。唯一例外：TenantDetail 证件号/手机号保留后端脱敏展示（ `****1234` ）。

二、角色定义

角色标识	中文名	定位	Mock 用户
`super_admin`	超级管理员	全系统控制	张总（工号 10001）
`operations_manager`	运营管理层	业务决策 + 审批	李经理（工号 10086）
`leasing_specialist`	租务专员	合同 + 租客日常操作	王专员（工号 20031）
`finance_staff`	财务人员	财务收支 + 核销	赵会计（工号 30012）
`maintenance_staff`	维修技工	工单接派 + 水电抄表	陈师傅（工号 40005）
`property_inspector`	楼管巡检员	资产查看 + 巡检登记	周楼管（工号 40010）
`report_viewer`	只读观察者	报表查看（投资人/审计）	钱投资（工号 50001）

默认角色： `operations_manager` （李经理）

三、权限字符串（Phase 1 范围）

完整权限字符串 21 个，按模块分组：

权限字符串	含义	SA	OM	LS	FS	MS	PI	RV
`assets.read`	查看资产	✅	✅	✅	✅	❌	✅	✅
`assets.write`	编辑资产	✅	✅	❌	❌	❌	❌	❌
`contracts.read`	查看合同	✅	✅	✅	✅	❌	✅[1]	✅[2]
`contracts.write`	编辑合同	✅	✅	✅	❌	❌	❌	❌
`deposit.read`	查看押金	✅	✅	✅	✅	❌	❌	✅
`deposit.write`	编辑押金	✅	✅	❌	✅	❌	❌	❌
`finance.read`	查看财务	✅	✅	✅[3]	✅	❌	❌	✅
`finance.write`	编辑财务	✅	❌	❌	✅	❌	❌	❌
`kpi.view`	查看 KPI	✅	✅	✅	✅	✅	✅	✅
`kpi.manage`	管理 KPI	✅	✅	❌	❌	❌	❌	❌
`kpi.appeal`	提交申诉	✅	✅	✅	✅	✅	✅	❌
`meterReading.write`	水电抄表	✅	✅	✅	✅	✅	✅	❌
`workorders.read`	查看工单	✅	✅	✅	❌	✅	✅	❌
`workorders.write`	编辑工单	✅	✅	❌	❌	✅	❌	❌
`sublease.read`	查看子租赁	✅	✅	✅	✅	❌	❌	✅
`sublease.write`	编辑子租赁	✅	✅	✅	❌	❌	❌	❌
`alerts.read`	查看预警	✅	✅	✅	✅	❌	❌	✅
`alerts.write`	处理预警	✅	✅	❌	❌	❌	❌	❌
`ops.read`	查看运维	✅	✅	❌	❌	❌	❌	❌
`ops.write`	编辑运维	✅	❌	❌	❌	❌	❌	❌
`org.read`	查看组织	✅	✅	✅	✅	❌	✅	✅
`org.manage`	管理组织	✅	✅	❌	❌	❌	❌	❌
`import.execute`	执行导入	✅	✅	✅[4]	✅[4]	❌	❌	❌

注释:

1. PI 的 `contracts.read` 限制为仅查看租客基本信息（姓名、房号），**不可查看财务金额字段**
2. RV 的 `contracts.read` 限制为不可查看租客敏感信息（证件号、手机号等 PII）
3. LS 的 `finance.read` 限制为仅查看关联账单，**不可查看全局 NOI 报表**
4. LS 仅可执行租务导入，FS 仅可执行财务导入

四、两层权限控制架构（v3.0 整区域隐藏）

```
┌──────────────────────────────────────────────────────┐
│  Layer 1: 路由守卫 (Page-level)                       │ ← 无权限 → 重定向首页
│  ROUTE_RULES[] + isRouteAllowed() + Layout.tsx guard  │
├──────────────────────────────────────────────────────┤
│  Layer 2: 整区域隐藏 (Section-level)                  │ ← 无权限 → 不渲染 DOM
│  <Can> 门控 + helper 函数条件渲染          │
└──────────────────────────────────────────────────────┘
```

> **v3.0 变更**: 移除 Layer 3 `<MaskedField>`（字段级 `***` 脱敏）。无权限时整块隐藏，不显示占位符。
> 唯一例外：TenantDetail 证件号/手机号保留后端已脱敏的 `****1234` 格式。

新增 Helper 函数

Helper	判断逻辑	隐藏对象
`canViewFinancialData(role)`	`role !== 'property_inspector' && role !== 'maintenance_staff'`	所有 ¥ 金额区域
`canViewPII(role)`	`['super_admin','operations_manager','finance_staff','leasing_specialist'].includes(role)`	证件号/手机号/联系方式
`canAccessGlobalNOI(role)`	SA/OM/RV 返回 true	已有，不变
`canViewContractAmounts(role)`	`role !== 'property_inspector'`	已有，不变

隐藏实现模式

```
// 1. 整区域隐藏（条件渲染）
{canViewFinancialData(role) && <FinancialInfoCard />}

// 2. 操作按钮门控
<Can permission="contracts.write"><Button>新建合同</Button></Can>

// 3. 列表列隐藏
const columns = baseColumns.filter(col =>
  col.key !== 'amount' || canViewFinancialData(role)
);
```

五、实施步骤

Phase A: Auth 基础设施（新建 4 个文件）

Step 1: 类型与权限常量

- 文件: `frontend/src/app/auth/types.ts`
- 内容:
  - `Role` 联合类型（5 个内部角色）
  - `Permission` 联合类型（21 个权限字符串）
  - `MockUser` 接口（id / name / title / role / employeeNo / permissions）
- 文件: `frontend/src/app/auth/permissions.ts`
- 内容:
  - `ROLE_PERMISSIONS` : `Record<Role, Permission[]>` 严格按 RBAC 矩阵
  - `MOCK_USERS` : 7 个预定义用户（排除 sub_landlord）
  - `hasPermission(role, permission)` 判定函数
  - `TAB_PERMISSIONS` : Tab 可见性映射
  - `ROUTE_PERMISSIONS` : 路由权限映射

Step 2: React Context

- 文件: `frontend/src/app/auth/AuthContext.tsx`
- 内容:
  - `AuthProvider` 包裹应用
  - `useAuth()` hook 暴露: `user` , `role` , `can(permission)` , `switchRole(role)`
  - `localStorage` 持久化当前角色选择
  - 默认角色: `operations_manager`

Step 3: 门控组件

- 文件: `frontend/src/app/auth/Can.tsx`
- 内容:
  - `<Can permission="xxx">` — 有权限渲染 children，无权限渲染 fallback 或不渲染
  - `<MaskedField permission="xxx" value="123">` — 无权限显示 `***`

Phase B: 导航层集成（修改 3 个文件）

Step 4: 注入 AuthProvider

- 文件: `frontend/src/app/routes.tsx`
- 修改: 在 Layout 外层包裹 `AuthProvider`

Step 5: Tab Bar 过滤

- 文件: `frontend/src/app/components/BottomTabBar.tsx`

- 修改: 根据 `TAB_PERMISSIONS` 过滤不可见 Tab

Tab	所需权限	SA	OM	LS	FS	MS	PI	RV
首页	— (所有人可见)	✅	✅	✅	✅	✅	✅	✅
资产	`assets.read`	✅	✅	✅	✅	❌	✅	✅
合同	`contracts.read`	✅	✅	✅	✅	❌	✅	✅
工单	`workorders.read`	✅	✅	✅	❌	✅	✅	❌
财务	`finance.read`	✅	✅	✅[3]	✅	❌	❌	✅

Step 6: 路由守卫

- 文件: `frontend/src/app/Layout.tsx`
- 修改: 对照 `ROUTE_PERMISSIONS` 表检查当前路径，无权限重定向 `/`

路由模式	所需权限	被阻断角色
`/noi`	`finance.read` （限 SA/OM/RV）	LS, FS, MS, PI
`/wale`	`contracts.read`	MS
`/finance/**`	`finance.read`	MS, PI
`/finance/kpi`	`kpi.view`	—
`/work-orders/**`	`workorders.read`	FS, RV
`/subleases`	`sublease.read`	MS, PI, RV
`/contracts/**`	`contracts.read`	MS
`/assets/**`	`assets.read`	MS

> 注: `/noi` 路由虽然 LS 有 `finance.read` ，但其权限限制为“仅关联账单”，NOI 全局报表不可见，因此特殊阻断。 `report_viewer` 可访问 NOI （只读）。

Phase C: 页面适配（修改 6 个页面）

Step 7: Home.tsx 角色化

区块	所需权限	SA	OM	LS	FS	MS	PI	RV
Header（标题 + 搜索）	—	✅	✅	✅	✅	✅	✅	✅
核心概览卡（出租率 hero）	`assets.read`	✅	✅	✅	✅	❌	✅	✅
核心概览卡（财务条）	`finance.read`	✅	✅	✅[3]	✅	❌	❌	✅
运营预警 AlertRadar	`alerts.read`	✅	✅	✅	✅	❌	❌	✅
常用应用 — 资产登记	`assets.write`	✅	✅	❌	❌	❌	❌	❌
常用应用 — 合同录入	`contracts.write`	✅	✅	✅	❌	❌	❌	❌
常用应用 — 查看账单	`finance.read`	✅	✅	✅[3]	✅	❌	❌	✅
常用应用 — 报修派单	`workorders.write`	✅	✅	❌	❌	✅	❌	❌
常用应用 — 财务总览	`finance.read`	✅	✅	❌	✅	❌	❌	✅
常用应用 — 续租管理	`contracts.write`	✅	✅	✅	❌	❌	❌	❌
常用应用 — 异常预警	`alerts.read`	✅	✅	✅	✅	❌	❌	✅
WALE 摘要	`contracts.read`	✅	✅	✅	✅	❌	✅	✅
待办任务	— (按类型过滤)	全部	全部	合同+子租赁	财务	工单	巡检+工单	无

Step 8: Assets.tsx 角色化

- 有 `assets.read` 的角色可查看（SA/OM/LS/FS/PI/RV），MS 无权限，页面不可达
- 编辑/导入按钮仅 SA/OM 可见（ `assets.write` ）
- RV 可查看但无任何操作按钮

Step 9: Contracts.tsx 角色化

- 列表查看: 有 `contracts.read` 的角色（SA/OM/LS/FS/PI/RV），MS 无权限
- 新建合同按钮: SA/OM/LS（ `contracts.write` ）
- 金额列: PI 时整列隐藏（ `canViewContractAmounts` ），不显示 `***`
- PII 列: RV 时隐藏联系方式列（ `canViewPII` ）

Step 10: WorkOrders.tsx 角色化

- 列表: SA/OM/LS/MS/PI（FS 和 RV 无权限，页面不可达）
- 新建工单: SA/OM/MS（ `workorders.write` ）
- 派单/验收: SA/OM（ `workorders.write` + 管理权限）

- PI 只读查看工单列表，无操作按钮

Step 11: Finance.tsx 角色化【已完成 — 升级为四视图独立渲染】

> 实际实现：Finance.tsx 未采用单布局局部条件渲染，而是按角色分支渲染完全独立的视图，实现零信息噪音体验。

角色	视图	Header 色	核心内容
`super_admin` / `operations_manager`	管理层视图	深蓝 `#0f2645`	NOI + WALE + 收入快报 + KPI/账单大卡 + 逾期列表
`finance_staff`	财务专员视图	深绿 `#064e3b`	今日待处理 7（账单×5 + 水电×2）+ 逾期列表
`leasing_specialist`	租务专员视图	蓝色 `#1a3a5c`	押金 + 营业额 + 收款进度组件
`maintenance_staff`	维修技工视图	深琥珀 `#78350f`	极简水电录入单卡 + 账单查看/KPI 二级入口
`property_inspector`	楼管巡检视图	深青 `#134e4a`	资产概览卡 + 水电抄表 + 工单只读列表 + 租客基本信息
`report_viewer`	只读观察视图	深紫 `#3b0764`	NOI + WALE + 出租率 + KPI 概览（全只读，零操作按钮）

- **MS（maintenance_staff）**：仅可达工单和首页，财务页不可达，展示极简水电录入 + 工单视图
- **PI（property_inspector）**：可达资产/合同（只读）/工单（只读），展示巡检视图 + 水电抄表 + 租客基本信息
- **RV（report_viewer）**：可达资产/合同/财务（全只读），展示 NOI + WALE + KPI 概览，零操作按钮
- **LS**：完整视图，包含押金 / 营业额申报 / 收款进度，无 NOI 卡片
- **NOI / WALE 入口**：管理层视图 + RV 只读视图展示，技术实现为 `['super_admin', 'operations_manager', 'report_viewer'].includes(role)` 分支

Step 12: Profile.tsx 角色切换

- 顶部显示当前 Mock 用户信息（名称、角色、工号）
- 新增「演示角色切换」区块:
  - 7 个角色按钮，当前角色高亮
  - 按辑排列：SA → OM → LS → FS → MS → PI → RV
  - 标注「演示功能」提示
  - 切换后自动刷新页面权限
- 菜单项按权限过滤:
  - 权限管理: 仅 SA/OM
  - 系统设置: 仅 SA

Phase D: 验证

Step 13: 编译验证

- `pnpm build` 零错误

Step 14: 合规复查

- 逐角色验证 Tab 可见性
- 逐角色验证路由守卫
- 逐角色验证 Home 各区块
- 逐角色验证字段脱敏
- 对照 RBAC_MATRIX.md 逐条检查

六、新建文件清单

文件	类型	说明
`frontend/src/app/auth/types.ts`	新建	类型定义
`frontend/src/app/auth/permissions.ts`	新建	权限常量表 + 工具函数
`frontend/src/app/auth/AuthContext.tsx`	新建	Context Provider + Hook
`frontend/src/app/auth/Can.tsx`	新建	门控组件 + 脱敏组件

七、修改文件清单

文件	修改内容
`routes.tsx`	注入 AuthProvider
`BottomTabBar.tsx`	Tab 按权限过滤
`Layout.tsx`	路由守卫 + 重定向
`Home.tsx`	各区块权限门控
`Assets.tsx`	编辑按钮权限控制
`Contracts.tsx`	新建按钮 + 金额脱敏
`WorkOrders.tsx`	新建/派单按钮权限
`Finance.tsx`	LS 限制 + NOI 门控
`Profile.tsx`	角色切换器 + 信息展示

八、页面级可见性规则（v3.0 新增）

> 详细的页面-角色矩阵请参见 **PAGE_ROLE_VISIBILITY_MATRIX.md**。

本节为摘要索引：

8.1 数据分级

- **L1 公开**: 楼栋名/单元号/状态 → 所有角色可见
- **L2 业务**: 出租率%/合同数/KPI 得分 → MS 仅工单域
- **L3 财务**: ¥ 金额/NOI/收款率 → PI/MS 不可见
- **L4 敏感**: 证件号/手机号 → 仅 SA/OM/FS/LS

8.2 页面覆盖总计

模块	页面数	需加固页面
Dashboard	2	Home
Assets	4	Assets, BuildingFloors, FloorPlan, UnitDetail
Contracts	4	Contracts, ContractDetail, EscalationTemplates, TenantDetail
Finance	14	Invoices, InvoiceDetail, PaymentList/Form, MeterReading×2, Expense×2, Turnover, Deposit, NoiBudget, CostReport, RevenueDetail
Analytics	5	NOIDashboard, WALEDashboard, KPIDashboard, KPISchemes, KPISchemeForm
WorkOrders	3	WorkOrders, WorkOrderDetail, Suppliers
Subleases	2	Subleases, SubleasePenetration
合计	**34**	**30+**

8.3 ROUTE_RULES 补全

当前 13 条 → 补全至 28 条，新增 15 条规则（完整清单见 MATRIX §5）。

九、验收基线

逐一切换 7 个 Mock 角色，验证：

1. 路由守卫: MS 不可达 `/assets`、`/contracts`；PI 不可达 `/finance`；RV 不可达 `/work-orders`
2. **Tab 可见性**: MS 仅见 首页+工单；PI 不见 财务
3. 整区域隐藏关键场景:

- ContractDetail 月租金 → PI 时整个财务卡片消失
- UnitDetail 月租金 → PI/MS 时租金信息卡片消失
- FloorPlan NOI 图层 → PI/MS 时图层选项灰色不可点
- KPIDashboard 全员排名 → 非 SA/OM 时排名区域消失
- WorkOrderDetail 费用分解 → PI/MS 时费用卡片消失

1. 零 **console error**: 切换角色后无报错
2. 零闪烁: 无先渲染后隐藏的视觉跳动